Integración de Servicios Cloud GCP

IAM: quién puede hacer qué y sobre qué recurso

Semana 11 - Sesión 22

Rel Guzman



Revisión: la arquitectura de la sesión anterior

Bloque	Lo que decidimos	La pregunta que faltó
Backend en una VM	Ejecuta las reglas de la aplicación	¿Con qué identidad guarda los archivos?
Bucket privado	Guarda facturas y reportes	¿Quién puede leerlos y quién puede crearlos?
Proyecto de Google Cloud	Agrupa la VM, el bucket y la red	¿Quién puede cambiar sus recursos?

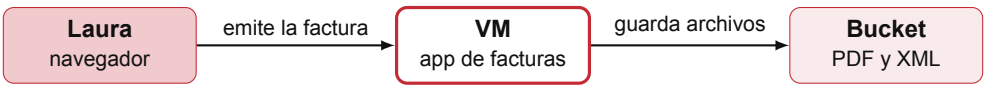
La pregunta de hoy

En la Sesión 21 dijimos que el backend solo debe acceder a lo que necesita. Hoy vemos **cómo** se configura eso en Google Cloud: con IAM.

Revisión: una aplicación de facturas

Pedidos Express (proyecto `pedidos-express-prod`)

Laura emite facturas desde el navegador. La aplicación corre en una VM de Compute Engine, crea el PDF y el XML y los guarda en el bucket `pe-facturas-prod`.



Pregunta rápida

Para que Laura pudiera descargar las facturas le dieron el rol **Editor** en todo el proyecto. Funciona. ¿Qué podría salir mal?

Logro de la sesión

Al finalizar, podrás explicar cómo IAM controla el acceso en Google Cloud, asignar a cada identidad el **rol** mínimo sobre el **recurso** que necesita y usar una **cuenta de servicio** para que una VM acceda a Cloud Storage sin usar la cuenta de una persona.

Saberes previos

- En una empresa, ¿la persona de contabilidad debería tener la llave del cuarto de servidores?
- Si una aplicación usa la cuenta personal de un desarrollador y esa persona deja la empresa, ¿qué le pasa a la aplicación?
- En el Lab 01 creaste un bucket. ¿Quién más podía ver sus archivos?

Utilidad de esta sesión

En un proyecto real casi nunca trabajas solo. Contabilidad necesita leer facturas, un desarrollador necesita desplegar una VM y la aplicación necesita guardar archivos. Con IAM das a cada uno **solo lo que su tarea requiere**, y un error de una persona no derriba todo el proyecto.

Plan de hoy: dos partes y una práctica

Parte	Qué vemos	Lo conectamos con
1. Teoría	Identidad, rol y recurso: las tres piezas de IAM	El caso de facturas de Pedidos Express
2. Teoría	Cuentas de servicio y el rol `Service Account User`	El laboratorio *Explora IAM*
Práctica	Corregir los permisos de un proyecto	Una tabla de identidad, recurso y rol

Regla de hoy

Si una identidad no necesita un permiso para su tarea, no se lo des.

Parte 1: quién, qué y sobre qué

Las tres piezas de una asignación de IAM

IAM en una frase



Pieza	En el caso de facturas
Identidad	`laura@pedidosexpress.com`
Rol	`Storage Object Viewer`: listar y descargar objetos
Recurso	El bucket `pe-facturas-prod`

Se lee así

“Laura puede ver los objetos del bucket de facturas”. Nada más: ni borrarlos, ni tocar la VM.

Identidades: personas y cuentas de servicio

Cuenta de una persona

Un correo como `laura@pedidosexpress.com`. La persona inicia sesión en la consola o en Cloud Shell.

En el lab

Trabajaste con dos usuarios: **Username 1** administraba el proyecto y **Username 2** solo tenía acceso de lectura.

Cuenta de servicio

Una identidad para una aplicación, no para una persona:

`sa-generador-facturas@pedidos-express-prod.iam.gserviceaccount.com`

No inicia sesión

Nadie escribe su contraseña. La VM la usa para llamar a otros servicios, como Cloud Storage.

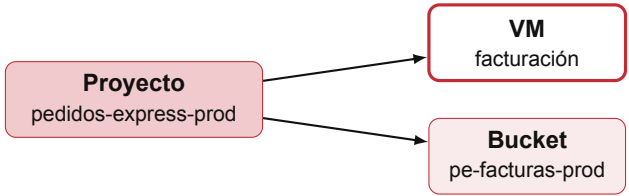
Roles: un paquete de permisos

Rol	Qué permite	Alcance
`Owner` / `Editor` / `Viewer`	Administrar, cambiar o ver casi todo	Muy amplio: roles básicos
`Storage Object Viewer`	Listar y descargar objetos	Solo Cloud Storage
`Storage Object Creator`	Crear objetos, sin leer ni borrar	Solo Cloud Storage
`Compute Instance Admin`	Crear y administrar VMs	Solo Compute Engine
`Service Account User`	Asociar una cuenta de servicio a una VM	Una cuenta de servicio

La idea clave

No asignas permisos sueltos: asignas un **rol**. Prefiere el rol más específico que cubra la tarea antes que `Editor`.

Dónde se asigna: proyecto o recurso



Rol en el proyecto

Vale para **todos** sus recursos. Se asigna en **IAM y administración > IAM**. En el lab diste `Storage Object Viewer` a Username 2 en el proyecto.

Rol en un recurso

Vale solo para **ese** recurso. Se asigna en la pestaña **Permisos** del bucket o de la cuenta de servicio.

Elige el lugar más pequeño

Si Laura solo usa un bucket, el rol va en ese bucket, no en el proyecto.

Mínimo privilegio: el problema de Laura

Antes: `Editor` **en el proyecto**

Laura descarga facturas, pero también podría borrar la VM, cambiar la red o modificar otros recursos por error.

Después: `Storage Object Viewer` **en el bucket**

Laura descarga las facturas para conciliarlas. No puede borrarlas ni tocar la infraestructura.

Principio de mínimo privilegio

Cada identidad recibe el permiso mínimo necesario para realizar su tarea, sobre el recurso más pequeño posible. Si luego necesita más, se le concede solo esa acción.

Dos pasos en la consola

1. **IAM y administración > IAM**: quitar a Laura el rol `Editor`.
2. **Cloud Storage > Buckets > pe-facturas-prod > Permisos**: agregar a Laura con `Storage Object Viewer`.

Parte 2: cuentas de servicio

Una VM que accede a Cloud Storage con su propia identidad

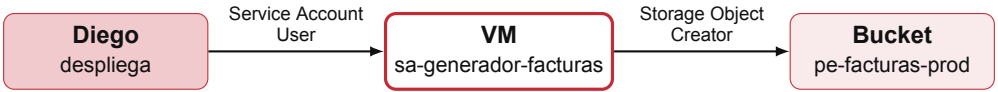
Lo que hiciste en *Explora IAM*

Paso	Qué hiciste	Qué comprobaste
Explorar la consola de IAM	Viste los roles de Username 1 y 2	Quién tiene qué rol
Preparar un bucket	Username 1 creó un bucket y subió `sample.txt`	Username 2 podía verlo
Quitar acceso al proyecto	Retiraste el rol `Viewer` a Username 2	Ya no ve el proyecto
Agregar permisos de almacenamiento	Diste `Storage Object Viewer` a Username 2	Lista el bucket desde Cloud Shell
Configurar una cuenta de servicio	Creaste `read-bucket-objects` y la VM `demoiam`	La VM lee, pero no escribe

Lo que muestra el lab

Al quitar un rol amplio y dar uno específico, Username 2 conserva justo lo que necesita: leer objetos.

Una VM con cuenta de servicio



La cuenta de servicio

`sa-generador-facturas` tiene `Storage Object Creator` sobre el bucket: crea el CSV diario, pero no lee ni borra facturas anteriores.

Diego

Tiene `Service Account User` sobre esa cuenta: puede elegirla al crear la VM, sin usar sus permisos desde su propia cuenta.

Igual que `demoiam` en el lab

Desde la VM, `gcloud compute instances list` falló y la copia hacia el bucket fue rechazada; descargar `sample.txt` sí funcionó. La VM solo hace lo que permite el rol de su cuenta de servicio.

Caso: la configuración de Pedidos Express

Identidad	Recurso	Rol	Motivo
Laura	Bucket `pe-facturas-prod`	`Storage Object Viewer`	Descarga facturas para conciliarlas
`sa-generador-facturas`	Bucket `pe-facturas-prod`	`Storage Object Creator`	La VM sube el CSV diario
Diego	Cuenta de servicio `sa-generador-facturas`	`Service Account User`	Asocia la cuenta a la VM

La factura no se guarda con la cuenta de Laura

Laura emite la factura; la VM guarda el PDF y el XML con su cuenta de servicio.

Si Diego deja la empresa

La aplicación sigue funcionando: usa su propia cuenta de servicio, no la de Diego.

Práctica: corrige los permisos de un proyecto

En grupos de dos

Una librería tiene el proyecto `libreria-prod`, una VM que genera reportes de ventas cada noche y el bucket `libreria-reportes`. Hoy **todos** tienen `Editor` en el proyecto.

Identidad	Tarea que realmente hace
Carla, contadora	Descarga los reportes para revisar las ventas
VM de reportes	Sube un reporte nuevo cada noche
Andrés, desarrollador	Crea la VM y le asocia su cuenta de servicio
Sofía, practicante	Solo necesita revisar la configuración, sin cambiar nada

Entregable

Una tabla con identidad, recurso, rol y motivo. Indiquen qué rol `Editor` retirarían.

Cierre: preguntas para comprobar

Responde con tus palabras

1. ¿Cuáles son las tres piezas de una asignación de IAM?
2. ¿Por qué dar `Editor` en el proyecto a Laura era un riesgo?
3. ¿Qué diferencia hay entre asignar un rol en el proyecto y en el bucket?
4. ¿Por qué la VM usa una cuenta de servicio y no la cuenta de un desarrollador?
5. ¿Para qué sirve el rol `Service Account User`?
6. En el lab, ¿por qué `demoiam` pudo leer `sample.txt` pero no escribir en el bucket?

Idea final

IAM responde siempre tres preguntas: quién, qué puede hacer y sobre qué recurso. La mejor respuesta es la más pequeña que permite trabajar.

Referencias

- Laboratorio: *Explora IAM*, curso *Essential Google Cloud Infrastructure: Core Services*: `cloudskillsboost.google/focuses/19082`.
- Material base de esta sesión: `/Users/rgap/Desktop/labs/ejemplo-explora-iam.md`.
- Diagrama del sistema desplegado: `labs/diagramas/iam_sistema_de_facturas_desplegado.md`.
- Simulación visual del caso: `labs/proyecto-facturas-web`.
- Material previo del curso: Sesión 21, arquitectura inicial de una webapp.
- Google Cloud: IAM, cuentas de servicio, Cloud Storage y Compute Engine.
- Las respuestas de las preguntas y de la práctica están en `../respuestas.md`.